PROJETO INTEGRADOR — FITSTORE

DISCIPLINA 3 — SEGURANÇA DA INFORMAÇÃO

Mapeamento de ameaças, políticas de segurança, LGPD e análise crítica

São Paulo
2026

DISCIPLINA 3 — SEGURANÇA DA INFORMAÇÃO

A FitStore é um projeto de loja virtual voltada para a venda de produtos fitness, como suplementos, roupas e acessórios de academia. O sistema foi planejado para permitir o cadastro de clientes, consulta de produtos, realização de pedidos e controle das informações da loja.

Nesta disciplina, analisamos os principais riscos de segurança que poderiam atingir a FitStore, definimos políticas para proteger o sistema e planejamos como os dados pessoais dos clientes serão tratados de acordo com a Lei Geral de Proteção de Dados (LGPD).

Como o projeto ainda está na fase de planejamento, as ameaças e as medidas de proteção apresentadas representam situações possíveis e soluções previstas para o futuro desenvolvimento da loja.

3.1 MAPEAMENTO DE AMEAÇAS E MATRIZ GUT

Para identificar quais ameaças precisam de mais atenção na FitStore, utilizamos a Matriz GUT. Ela considera três fatores: Gravidade (G), Urgência (U) e Tendência (T), com notas de 1 a 5. O resultado é calculado multiplicando os três valores: GUT = G × U × T.

As ameaças foram selecionadas com base em riscos conhecidos e documentados por organizações de segurança, como a OWASP e a MITRE/CWE. As notas representam nossa avaliação dos possíveis impactos dessas falhas na FitStore.

3.1.1 Matriz GUT

Nº	Ameaça	G	U	T	Total
01	Falhas de Autenticação	4	5	4	80
02	Controle de Acesso Quebrado	4	5	4	80
03	SQL Injection	5	5	5	125
04	Falhas Criptográficas	4	4	3	48
05	Configuração Incorreta	4	5	4	80
06	XSS	4	4	4	64
07	CSRF	4	5	4	80
08	SSRF	4	4	4	64
09	Path Traversal	4	3	3	36
10	Unrestricted File Upload	5	5	4	100
11	Clickjacking	4	5	4	80
12	XXE	4	4	4	64
13	Insecure Deserialization	4	5	4	80
14	Open Redirect	4	4	4	64
15	Dados Sensíveis em Logs	4	4	3	48
16	Mass Assignment	4	4	3	48
17	HTTP Parameter Pollution	4	4	4	64
18	SSTI	5	5	4	100
19	Componentes Desatualizados	4	4	5	80
20	Falhas de Integridade	4	4	4	64

3.1.2 Justificativas das ameaças

01 — Falhas de Autenticação

Na FitStore, essa falha poderia acontecer caso a tela de login não tivesse uma boa proteção. Com isso, criminosos poderiam tentar descobrir senhas e entrar nas contas dos clientes, conseguindo acessar informações pessoais e pedidos realizados.

02 — Controle de Acesso Quebrado

Essa falha poderia acontecer caso um cliente conseguisse acessar informações de outra pessoa ou entrar em áreas que deveriam ser restritas aos funcionários. Isso poderia causar vazamento de dados e alterações indevidas nos pedidos ou produtos da FitStore.

03 — SQL Injection

Na FitStore, essa vulnerabilidade poderia acontecer caso os campos de login ou busca de produtos não fossem protegidos corretamente. Um invasor poderia tentar inserir comandos maliciosos para manipular as consultas ao banco de dados, colocando em risco informações dos clientes, pedidos e estoque.

04 — Falhas Criptográficas

Essa falha poderia acontecer caso a FitStore não protegesse corretamente informações importantes, como dados pessoais e informações enviadas durante o login. Com isso, criminosos poderiam conseguir acessar dados confidenciais, prejudicando os clientes e a segurança da loja.

05 — Configuração Incorreta

Na FitStore, essa ameaça poderia acontecer caso o servidor, o banco de dados ou alguma configuração do sistema estivesse com permissões incorretas. Isso poderia facilitar acessos não autorizados e deixar informações importantes da empresa expostas.

06 — XSS

Essa vulnerabilidade poderia acontecer caso a FitStore permitisse comentários ou avaliações de produtos sem tratar corretamente o conteúdo enviado. Um criminoso poderia tentar inserir um código malicioso que seria executado no navegador de outros clientes, colocando suas contas e informações em risco.

07 — CSRF

Na FitStore, essa falha poderia acontecer caso um cliente estivesse conectado à sua conta e fosse induzido a acessar um link malicioso. Dependendo das proteções do site, isso poderia fazer o navegador enviar uma solicitação sem a intenção do cliente, como alterar informações da conta.

08 — SSRF

Essa ameaça poderia acontecer caso a FitStore tivesse alguma função que buscasse informações de outros sites, como imagens ou arquivos, sem verificar corretamente os endereços informados. Um invasor poderia tentar utilizar essa função para fazer o servidor acessar recursos internos que deveriam ser protegidos.

09 — Path Traversal

Na FitStore, essa falha poderia acontecer caso o sistema permitisse acessar arquivos por meio de caminhos informados pelo usuário, sem verificar se eles são permitidos. Com isso, um criminoso poderia tentar visualizar arquivos internos que não deveriam ficar disponíveis aos clientes.

10 — Unrestricted File Upload

Essa vulnerabilidade poderia acontecer caso a FitStore permitisse o envio de arquivos, como imagens de produtos ou anexos enviados ao suporte, sem verificar o tipo e o conteúdo. Um invasor poderia tentar enviar arquivos maliciosos para comprometer o servidor ou acessar informações da empresa.

11 — Clickjacking

Na FitStore, essa ameaça poderia acontecer caso uma página da loja pudesse ser colocada dentro de outro site sem proteção. Um criminoso poderia criar uma página enganosa para fazer o cliente clicar em botões da FitStore sem perceber, podendo realizar ações que não desejava.

12 — XXE

Essa falha poderia acontecer caso a FitStore utilizasse arquivos XML para integrar informações de pedidos, estoque ou fornecedores, sem configurar corretamente a leitura desses arquivos. Um invasor poderia tentar explorar essa função para acessar arquivos internos ou fazer solicitações indevidas pelo servidor.

13 — Insecure Deserialization

Na FitStore, essa vulnerabilidade poderia acontecer caso o sistema recebesse informações armazenadas em objetos e não verificasse corretamente se elas foram alteradas. Dependendo da tecnologia utilizada, um invasor poderia manipular esses dados para realizar ações não autorizadas ou comprometer o sistema.

14 — Open Redirect

Essa falha poderia acontecer caso a FitStore permitisse redirecionar os clientes para outros sites sem verificar o destino. Um criminoso poderia criar um link que parecesse ser da loja, mas que levasse o cliente para uma página falsa, tentando roubar suas informações.

15 — Dados Sensíveis em Logs

Na FitStore, essa ameaça poderia acontecer caso o sistema registrasse informações confidenciais nos arquivos de monitoramento, como senhas, tokens de acesso ou dados pessoais desnecessários. Se alguém conseguisse acessar esses registros, poderia utilizar essas informações de maneira indevida.

16 — Mass Assignment

Essa vulnerabilidade poderia acontecer caso a FitStore aceitasse alterações em informações do cadastro sem verificar quais campos o cliente realmente tem permissão para modificar. Um invasor poderia tentar alterar dados restritos, como o nível de acesso de uma conta ou informações administrativas.

17 — HTTP Parameter Pollution

Na FitStore, essa falha poderia acontecer caso o sistema não tratasse corretamente parâmetros repetidos enviados em uma solicitação. Um criminoso poderia tentar confundir a validação das informações e provocar comportamentos inesperados em funções como busca de produtos, filtros ou processamento de pedidos.

18 — SSTI

Essa vulnerabilidade poderia acontecer caso a FitStore utilizasse modelos de páginas ou mensagens gerados no servidor e permitisse que informações enviadas pelo usuário fossem interpretadas como comandos. Dependendo da tecnologia utilizada, um invasor poderia tentar acessar informações internas ou executar ações indevidas no servidor.

19 — Componentes Desatualizados

Na FitStore, essa ameaça poderia acontecer caso o site utilizasse bibliotecas, programas ou componentes antigos que já possuem falhas de segurança conhecidas. Criminosos poderiam tentar aproveitar essas vulnerabilidades para acessar informações ou comprometer o funcionamento da loja.

20 — Falhas de Integridade

Essa falha poderia acontecer caso a FitStore utilizasse atualizações, bibliotecas ou informações recebidas de outros sistemas sem verificar sua origem e integridade. Com isso, a empresa poderia acabar utilizando componentes ou dados modificados por pessoas mal-intencionadas, colocando o sistema em risco.

3.1.3 Classificação das prioridades

1º lugar — SQL Injection: 125 pontos.

2º lugar — SSTI: 100 pontos.

2º lugar — Unrestricted File Upload: 100 pontos.

Depois de analisar as 20 ameaças na Matriz GUT, identificamos que o SQL Injection foi o risco com a maior pontuação, chegando a 125 pontos. Isso acontece porque, se essa falha existir na FitStore, um invasor poderá tentar acessar ou modificar informações importantes do banco de dados, como dados dos clientes, pedidos e estoque. Por esse motivo, consideramos essa ameaça a principal prioridade de segurança do projeto.

As ameaças SSTI e Unrestricted File Upload ficaram empatadas em segundo lugar, com 100 pontos cada. Com essa análise, conseguimos identificar quais riscos precisam de mais atenção durante o desenvolvimento da FitStore e planejar medidas de segurança para evitar possíveis problemas.

3.2 POLÍTICAS DE SEGURANÇA DA INFORMAÇÃO

Para proteger a FitStore, definimos 20 políticas de segurança que deverão ser consideradas durante o desenvolvimento e o funcionamento da loja. Cada política tem o objetivo de diminuir os riscos e proteger as informações dos clientes e da empresa.

01 — Uso de senhas fortes

Os clientes e funcionários deverão utilizar senhas seguras para acessar suas contas.

Justificativa: Isso ajuda a dificultar que outras pessoas descubram as senhas e consigam entrar nas contas sem autorização.

02 — Autenticação em duas etapas

Planejamos utilizar uma segunda forma de verificação, principalmente nas contas dos administradores.

Justificativa: Mesmo que alguém descubra uma senha, terá mais dificuldade para acessar a conta.

03 — Controle de acesso por função

Cada funcionário deverá ter acesso somente às informações necessárias para realizar seu trabalho.

Justificativa: Isso evita que pessoas sem autorização consigam alterar produtos, pedidos ou dados dos clientes.

04 — Atualizações de segurança

O sistema e seus componentes deverão receber atualizações de segurança sempre que necessário.

Justificativa: Isso ajuda a corrigir falhas conhecidas que poderiam ser aproveitadas por criminosos.

05 — Backup das informações

A FitStore deverá realizar cópias de segurança dos dados importantes, com testes de recuperação.

Justificativa: Caso aconteça algum problema, será possível recuperar as informações e diminuir os prejuízos.

06 — Proteção dos dados por criptografia

Os dados deverão ser protegidos durante a transmissão e, quando necessário, no armazenamento. As senhas deverão ser armazenadas com técnicas adequadas de hash.

Justificativa: Isso dificulta que informações importantes sejam utilizadas por pessoas sem autorização.

07 — Proteção contra arquivos maliciosos

O sistema deverá utilizar medidas para identificar e bloquear arquivos perigosos.

Justificativa: Isso ajuda a impedir que arquivos maliciosos comprometam a loja ou seus servidores.

08 — Monitoramento de acessos

A FitStore deverá registrar e acompanhar acessos suspeitos ao sistema.

Justificativa: Isso ajuda a identificar possíveis tentativas de invasão e permite agir mais rapidamente.

09 — Limite de tentativas de login

O sistema deverá limitar tentativas repetidas de acesso e aplicar outras proteções contra ataques automatizados.

Justificativa: Isso dificulta que criminosos tentem descobrir as senhas dos clientes.

10 — Verificação de arquivos enviados

Arquivos enviados ao sistema deverão passar por verificações de tipo, tamanho e segurança.

Justificativa: Isso diminui o risco de alguém enviar arquivos maliciosos para comprometer a FitStore.

11 — Proteção dos dados pessoais

A FitStore deverá coletar somente as informações necessárias e utilizar os dados para finalidades definidas.

Justificativa: Isso ajuda a proteger a privacidade dos clientes e a respeitar a LGPD.

12 — Uso de HTTPS

A comunicação entre o navegador do cliente e a FitStore deverá utilizar HTTPS.

Justificativa: Isso ajuda a proteger as informações transmitidas, principalmente durante o login e a realização de pedidos.

13 — Controle de contas dos funcionários

As contas dos funcionários deverão ser criadas conforme suas funções e desativadas quando não forem mais necessárias.

Justificativa: Isso evita que pessoas que não trabalham mais na empresa continuem tendo acesso ao sistema.

14 — Segurança do banco de dados

O banco de dados deverá utilizar permissões restritas, consultas parametrizadas e outras medidas de proteção.

Justificativa: Isso ajuda a evitar acessos indevidos, alterações não autorizadas e ataques como SQL Injection.

15 — Orientação dos funcionários

Os funcionários deverão receber orientações sobre senhas, golpes e cuidados com informações confidenciais.

Justificativa: Isso diminui os riscos causados por erros humanos e tentativas de enganar os funcionários.

16 — Encerramento de sessões

O sistema deverá encerrar sessões após um período adequado de inatividade, principalmente em áreas administrativas.

Justificativa: Isso diminui o risco de outra pessoa utilizar uma conta que ficou aberta.

17 — Resposta a incidentes

A FitStore deverá ter um procedimento para identificar, registrar e resolver problemas de segurança.

Justificativa: Isso ajuda a empresa a agir rapidamente e diminuir os danos caso aconteça algum incidente.

18 — Segurança dos serviços externos

Os serviços utilizados pela FitStore, como meios de pagamento e entrega, deverão ser avaliados quanto à segurança e à proteção de dados.

Justificativa: Isso ajuda a diminuir os riscos relacionados ao compartilhamento de informações com outras empresas.

19 — Exclusão segura de informações

Os dados que não precisarem mais ser mantidos deverão ser eliminados de forma segura, respeitando as obrigações legais.

Justificativa: Isso evita o armazenamento desnecessário de informações e diminui o risco de vazamentos.

20 — Revisão das políticas de segurança

As políticas deverão ser revisadas sempre que houver mudanças importantes no sistema ou novos riscos identificados.

Justificativa: Isso ajuda a manter a segurança da FitStore atualizada conforme o projeto evolui.

3.3 REGISTRO DE OPERAÇÕES DE TRATAMENTO DE DADOS PESSOAIS (ROPA) — LGPD

Para planejar a proteção dos dados pessoais na FitStore, elaboramos 20 registros de tratamento. Cada registro apresenta o dado ou processo, a finalidade, a base legal prevista e os direitos do titular. As bases legais foram escolhidas considerando as funcionalidades planejadas. Elas deverão ser confirmadas quando os processos reais da loja forem definidos.

01 — Nome completo

Dado/Processo: Nome completo do cliente.

Finalidade: Identificar o cliente durante o cadastro e a realização de pedidos.

Base legal: Art. 7º, V — execução de contrato.

Direitos do titular: O cliente poderá consultar e corrigir seu nome e solicitar a exclusão quando não existir uma justificativa legal para manter o dado.

02 — CPF

Dado/Processo: CPF do cliente, quando necessário para emissão de documentos fiscais.

Finalidade: Cumprir as obrigações fiscais relacionadas às compras.

Base legal: Art. 7º, II — cumprimento de obrigação legal ou regulatória.

Direitos do titular: O cliente poderá solicitar acesso e correção do CPF. A exclusão dependerá das obrigações legais de conservação.

03 — E-mail

Dado/Processo: Endereço de e-mail do cliente.

Finalidade: Permitir o acesso à conta e enviar informações relacionadas aos pedidos.

Base legal: Art. 7º, V — execução de contrato.

Direitos do titular: O cliente poderá consultar e atualizar seu e-mail e solicitar a exclusão quando não existir necessidade de conservação.

04 — Telefone

Dado/Processo: Número de telefone do cliente, quando necessário.

Finalidade: Entrar em contato sobre entregas e problemas relacionados aos pedidos.

Base legal: Art. 7º, V — execução de contrato, quando o telefone for necessário para prestar o serviço.

Direitos do titular: O cliente poderá consultar, corrigir e solicitar a exclusão do número, respeitando eventuais necessidades legais.

05 — Endereço de entrega

Dado/Processo: Endereço informado para receber os produtos.

Finalidade: Permitir que os pedidos sejam entregues corretamente.

Base legal: Art. 7º, V — execução de contrato.

Direitos do titular: O cliente poderá corrigir o endereço e solicitar a exclusão quando não existir justificativa para sua conservação.

06 — Data de nascimento

Dado/Processo: Data de nascimento do cliente, somente se for necessária para alguma funcionalidade específica.

Finalidade: Verificar a idade quando isso for necessário para utilizar determinado serviço ou cumprir uma exigência aplicável.

Base legal: Art. 7º, V — execução de contrato, quando o dado for realmente necessário.

Direitos do titular: O cliente poderá consultar e corrigir a informação, além de solicitar a exclusão quando não existir justificativa legal. Observação: a FitStore não pretende solicitar esse dado no cadastro comum enquanto não houver uma necessidade definida.

07 — Endereço IP e registros de acesso

Dado/Processo: Endereço IP, data e horário dos acessos.

Finalidade: Cumprir obrigações legais aplicáveis e ajudar a identificar problemas de segurança.

Base legal: Art. 7º, II — cumprimento de obrigação legal, quando aplicável. Para registros adicionais de segurança, poderá ser avaliado o art. 7º, IX — legítimo interesse.

Direitos do titular: O cliente poderá solicitar acesso e correção, quando possível, e pedir a exclusão quando não existir obrigação de conservação.

08 — Cookies de publicidade

Dado/Processo: Cookies utilizados para acompanhar preferências relacionadas à publicidade.

Finalidade: Apresentar anúncios e conteúdos promocionais personalizados.

Base legal: Art. 7º, I — consentimento, conforme o modelo planejado.

Direitos do titular: O cliente poderá aceitar ou recusar esses cookies e retirar seu consentimento posteriormente.

09 — Histórico de compras

Dado/Processo: Registro dos produtos comprados pelo cliente.

Finalidade: Permitir o acompanhamento dos pedidos e manter registros necessários das compras.

Base legal: Art. 7º, V — execução de contrato; e art. 7º, II, quando houver obrigação legal de conservação.

Direitos do titular: O cliente poderá consultar seu histórico e solicitar correções ou exclusão quando permitidas pela legislação.

10 — Dados de pagamento

Dado/Processo: Informações necessárias para processar e confirmar pagamentos.

Finalidade: Permitir que os clientes realizem compras na FitStore.

Base legal: Art. 7º, V — execução de contrato; e art. 7º, II, para obrigações legais aplicáveis.

Direitos do titular: O cliente poderá solicitar acesso e correção dos dados tratados pela FitStore, além de exclusão quando permitida. Observação: o planejamento prevê utilizar um intermediador de pagamentos, evitando armazenar diretamente dados completos de cartões.

11 — Nome do destinatário da entrega

Dado/Processo: Nome da pessoa que receberá o pedido, quando for diferente do comprador.

Finalidade: Identificar o destinatário e ajudar a transportadora a realizar a entrega corretamente.

Base legal: Art. 7º, V — execução de contrato, quando aplicável ao próprio titular. Quando o destinatário for uma terceira pessoa, deverá ser avaliada uma base adequada, como o art. 7º, IX — legítimo interesse, considerando seus direitos.

Direitos do titular: O destinatário poderá solicitar acesso, correção e exclusão quando não existir justificativa legal para manter os dados.

12 — Rastreamento de entrega

Dado/Processo: Informações sobre o andamento e a localização da entrega.

Finalidade: Permitir que o cliente acompanhe seu pedido.

Base legal: Art. 7º, V — execução de contrato.

Direitos do titular: O cliente poderá consultar as informações, solicitar correções e pedir exclusão quando permitida.

13 — Mensagens de suporte

Dado/Processo: Mensagens enviadas pelo cliente para resolver dúvidas ou problemas relacionados aos pedidos.

Finalidade: Prestar atendimento e solucionar problemas.

Base legal: Art. 7º, V — execução de contrato, quando o atendimento estiver relacionado à compra.

Direitos do titular: O cliente poderá solicitar acesso e correção de dados incorretos, além da exclusão quando não existir justificativa para manter as mensagens.

14 — Avaliações de produtos

Dado/Processo: Comentários e avaliações enviados pelos clientes.

Finalidade: Permitir que os consumidores compartilhem suas opiniões sobre os produtos.

Base legal: Art. 7º, I — consentimento, conforme o modelo de publicação planejado.

Direitos do titular: O cliente poderá solicitar a correção ou remoção da avaliação e retirar o consentimento quando aplicável.

15 — E-mails promocionais

Dado/Processo: E-mail e preferência de recebimento de ofertas.

Finalidade: Enviar novidades, descontos e promoções da FitStore.

Base legal: Art. 7º, I — consentimento.

Direitos do titular: O cliente poderá cancelar o recebimento das mensagens e retirar o consentimento quando desejar.

16 — Login e autenticação

Dado/Processo: Identificador da conta e informações necessárias para autenticação.

Finalidade: Permitir o acesso seguro dos clientes ao sistema.

Base legal: Art. 7º, V — execução de contrato.

Direitos do titular: O cliente poderá corrigir informações da conta, alterar sua senha e solicitar a exclusão do cadastro quando permitida. Observação: as senhas deverão ser protegidas por hash seguro, sem armazenamento em texto simples.

17 — Lista de desejos

Dado/Processo: Produtos salvos pelo cliente para consultar posteriormente.

Finalidade: Permitir que o cliente organize produtos de seu interesse, caso essa funcionalidade seja desenvolvida.

Base legal: Art. 7º, V — execução de contrato, quando a funcionalidade fizer parte do serviço solicitado.

Direitos do titular: O cliente poderá adicionar e remover produtos e solicitar a exclusão dessas informações.

18 — Devoluções e reembolsos

Dado/Processo: Informações relacionadas às solicitações de troca, devolução e reembolso.

Finalidade: Resolver solicitações dos clientes e cumprir os direitos relacionados às compras.

Base legal: Art. 7º, V — execução de contrato; e art. 7º, II, quando houver obrigação legal aplicável.

Direitos do titular: O cliente poderá consultar e corrigir suas informações e solicitar a exclusão quando permitida.

19 — Registro de tentativas de login

Dado/Processo: Registros de tentativas de acesso, incluindo data, horário e informações necessárias para identificar atividades suspeitas.

Finalidade: Proteger as contas dos clientes e identificar possíveis tentativas de invasão.

Base legal: Art. 7º, IX — legítimo interesse, desde que seja realizada uma avaliação da necessidade do tratamento e dos direitos dos titulares.

Direitos do titular: O cliente poderá solicitar informações sobre os registros, pedir correções quando cabíveis e solicitar a exclusão quando não existir justificativa para conservação.

20 — Preferências de produtos

Dado/Processo: Informações sobre preferências de produtos utilizadas para personalização.

Finalidade: Apresentar recomendações de produtos conforme os interesses dos clientes, caso essa função seja desenvolvida.

Base legal: Art. 7º, I — consentimento, conforme o modelo planejado.

Direitos do titular: O cliente poderá alterar suas preferências, retirar o consentimento e solicitar a exclusão dessas informações.

3.3.1 Considerações sobre a LGPD

Na FitStore, planejamos utilizar os dados pessoais dos clientes apenas quando forem necessários para o funcionamento da loja, como no cadastro, nas compras, nos pagamentos e nas entregas. Também consideramos que algumas informações, como preferências de produtos e dados usados para publicidade, precisam de uma finalidade bem definida e de uma base legal adequada.

Os clientes poderão solicitar acesso e correção de seus dados, além de pedir a exclusão quando ela for permitida pela legislação. Como a FitStore ainda está em planejamento, essas medidas fazem parte das regras que definimos para o futuro desenvolvimento do sistema, buscando proteger as informações e respeitar a LGPD.

3.4 ANÁLISE CRÍTICA DA VULNERABILIDADE PRIORITÁRIA

De acordo com a nossa Matriz GUT, o SQL Injection foi a vulnerabilidade que recebeu a maior pontuação, com 125 pontos. Na FitStore, esse ataque poderia acontecer na tela de login, caso os dados digitados pelo cliente fossem colocados diretamente em uma consulta SQL, sem a proteção adequada. Um invasor poderia inserir um comando malicioso no campo de e-mail ou senha para tentar alterar a consulta ao banco de dados e conseguir acessar informações sem autorização. Isso poderia colocar em risco os dados dos clientes, funcionários, pedidos e estoque, causando prejuízos para a empresa.

Para evitar esse problema, pesquisamos e escolhemos utilizar consultas parametrizadas (prepared statements) no desenvolvimento do back-end da FitStore. Essa técnica separa os dados digitados pelo usuário dos comandos SQL, impedindo que essas informações sejam interpretadas como parte da consulta. Também planejamos limitar as permissões de acesso ao banco de dados e realizar testes de segurança. Como o projeto ainda está na fase de planejamento, essas medidas foram definidas para uma futura implementação, não sendo possível afirmar que já foram aplicadas ou testadas no sistema.

REFERÊNCIAS

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm.

OWASP FOUNDATION. OWASP Top 10:2025. Disponível em: https://top10.owasp.org/2025/.

OWASP FOUNDATION. OWASP Web Security Testing Guide. Disponível em: https://owasp.org/www-project-web-security-testing-guide/.

OWASP FOUNDATION. SQL Injection Prevention Cheat Sheet. Disponível em: https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html.

MITRE. Common Weakness Enumeration (CWE). Disponível em: https://cwe.mitre.org/.

CVE PROGRAM. Common Vulnerabilities and Exposures. Disponível em: https://www.cve.org/.

Referências técnicas das 20 ameaças

01. Falhas de Autenticação. Disponível em: https://top10.owasp.org/2025/A07_2025-Authentication_Failures/

02. Controle de Acesso Quebrado. Disponível em: https://top10.owasp.org/2025/A01_2025-Broken_Access_Control/

03. SQL Injection. Disponível em: https://cwe.mitre.org/data/definitions/89.html

04. Falhas Criptográficas. Disponível em: https://top10.owasp.org/2025/A04_2025-Cryptographic_Failures/

05. Configuração Incorreta. Disponível em: https://top10.owasp.org/2025/A02_2025-Security_Misconfiguration/

06. XSS. Disponível em: https://cwe.mitre.org/data/definitions/79.html

07. CSRF. Disponível em: https://cwe.mitre.org/data/definitions/352.html

08. SSRF. Disponível em: https://cwe.mitre.org/data/definitions/918.html

09. Path Traversal. Disponível em: https://cwe.mitre.org/data/definitions/22.html

10. Unrestricted File Upload. Disponível em: https://cwe.mitre.org/data/definitions/434.html

11. Clickjacking. Disponível em: https://cwe.mitre.org/data/definitions/1021.html

12. XXE. Disponível em: https://cwe.mitre.org/data/definitions/611.html

13. Insecure Deserialization. Disponível em: https://cwe.mitre.org/data/definitions/502.html

14. Open Redirect. Disponível em: https://cwe.mitre.org/data/definitions/601.html

15. Dados Sensíveis em Logs. Disponível em: https://cwe.mitre.org/data/definitions/532.html

16. Mass Assignment. Disponível em: https://cwe.mitre.org/data/definitions/915.html

17. HTTP Parameter Pollution. Disponível em: https://cwe.mitre.org/data/definitions/235.html

18. SSTI. Disponível em: https://cwe.mitre.org/data/definitions/1336.html

19. Componentes Desatualizados. Disponível em: https://cwe.mitre.org/data/definitions/1104.html

20. Falhas de Integridade. Disponível em: https://top10.owasp.org/2025/A08_2025-Software_or_Data_Integrity_Failures/

Nota: as referências CWE identificam tipos de fraquezas, não ocorrências CVE específicas. As medidas descritas neste documento são propostas de planejamento e não foram implementadas ou testadas na FitStore.